Cloud Security Digital Twin: Predicting Attack Paths in a Simulated Cloud Environment

Prepared by: Abd Alwahed Haj Omar, Avner Sehayek, Alaa Salawda
Date: 16/09/2026

1. Introduction

In cloud computing, a single compromised component (such as a web server, a user credential, or a storage bucket) can create a cascade of security failures. The critical question for defenders is: **"If one part of our system is breached, how far can an attacker go, and what can they access next?"**

This project proposes building a Cloud Security Digital Twin to answer that question. The goal is to create a prototype system that can predict the "blast radius" of a compromised cloud workload. Instead of just identifying static security risks, this system aims to model the dynamic relationships between cloud components to forecast an attacker's potential path through the network.

2. Project Objective

The primary objective is to research and demonstrate whether a security graph, automatically generated from a cloud environment's configuration, can accurately predict the attack paths and potential impact of a security breach.

The project will focus on:

1. Building a small, simulated cloud environment.
2. Creating a "digital twin" (a security graph) that models the relationships and permissions within that environment.
3. Testing the graph's predictive accuracy by comparing its forecasts against actual, controlled attacks.

3. Methodology

The project will be executed in five key phases:

Phase 1: Environment Simulation
A controlled cloud environment will be built locally to avoid the cost and complexity of a real cloud provider.

- **Kubernetes:** Used to run simulated applications, including a Web Pod (user-facing) and an API Pod (back-end service).
- **LocalStack:** Used to simulate selected AWS services, such as S3 (storage), IAM (identities and permissions), and Secrets Manager.

Phase 2: Digital Twin Creation

A software program will be developed to automatically collect configuration data from both Kubernetes and LocalStack. This data will be transformed into a single, unified **security graph**. The graph will map out critical relationships, such as:

- Which identity a workload uses.
- What permissions that identity has.
- Which resources it can access (e.g., databases, storage).
- Which other workloads it can communicate with over the network.

Phase 3: Attack Prediction

Starting from a hypothetical compromised component (e.g., the Web Pod), the system will traverse the security graph. By following the modeled identities, permissions, and network paths, it will calculate and output all possible **attack paths** an adversary could take.

Phase 4: Validation through Controlled Attacks

To test the prediction's accuracy, controlled attacks will be performed within the simulated environment. For example, a script will be run from the Web Pod to see what resources it can actually access. The real-world results of these attacks will be recorded.

Phase 5: Comparative Analysis

The predicted attack paths from Phase 3 will be directly compared against the actual attack paths from Phase 4. The analysis will measure:

- **Accuracy:** How many predicted paths were correct?
- **Missed Paths:** Were there attack paths the model failed to predict?
- **Incorrect Paths:** Did the model predict paths that were not actually possible?
- **Blast Radius Precision:** How accurately did the model predict the full scope of the compromise?

4. The Research Contribution

The core contribution of this project is not the act of drawing a graph, but the **empirical validation of its predictive power**. This research aims to determine if a security digital twin can be a reliable tool for proactively understanding and mitigating risk in cloud environments.

The final report will present a balanced analysis, highlighting both the successful predictions and, crucially, the cases where the model was inaccurate. This honest assessment will provide valuable insight into the limitations and potential of using digital twins for cloud security posture management.